SECURITY REQUIREMENTS SPECIFICATION

Project: LearnLink - Social Learning Community

Document Type:	Security Requirements	**Architecture:**	Layered Architecture (Django)
Version:	1.0 (Aligned with Proposal v1.1)	**Status:**	Ready for Development & Threat Analysis

เอกสารฉบับนี้กำหนดข้อกำหนดด้านความปลอดภัย (Security Requirements) สำหรับระบบ LearnLink - Social Learning Community ซึ่งออกแบบภายใต้สถาปัตยกรรม Layered Architecture บน Django Framework โดยแยกกลไกความปลอดภัยออกจากBusinessLogicเพื่อให้ทุกโมดูลเรียกใช้มาตรฐานความปลอดภัยจากส่วนกลางได้อย่างสม่ำเสมอ

1. ภาพรวมข้อกำหนดด้านความปลอดภัย (System-Wide Security Requirements)

ข้อกำหนดระดับโครงสร้างพื้นฐานที่ทุก Module ในระบบ Django Application ต้องปฏิบัติตามอย่างเคร่งครัด:

Req ID	หมวดหมู่ (Category)	ข้อกำหนดด้านความปลอดภัย (Security Requirement)
SR-SYS-01	**Server-Side Enforcement**	การตรวจสอบตัวตน (Authentication) และสิทธิ์การเข้าถึง (Authorization) ทุกอย่างต้องทำที่ฝั่ง Backend เท่านั้น ห้ามใช้การซ่อนปุ่มบน Frontend เป็นการควบคุมสิทธิ์เพียงอย่างเดียว
SR-SYS-02	**Default Deny & Least Privilege**	ระบบต้องยึดหลัก Default Deny (ปฏิเสธการเข้าถึงไว้ก่อนหากไม่มีกฎอนุญาตชัดเจน) และ Least Privilege (ให้สิทธิ์เท่าที่จำเป็นตาม Role: Guest, Member, Moderator, Administrator)
SR-SYS-03	**IDOR & Ownership Protection**	ทุก Endpoint ที่มีการรับ id ของผู้ใช้งานหรือข้อมูล (เช่น Post, Comment, Community, Media) ต้องตรวจสอบความเป็นเจ้าของ (Ownership Validation) ก่อนอนุญาตให้แก้ไขหรือลบข้อมูล
SR-SYS-04	**Data Confidentiality & Secrets**	ห้ามเก็บรหัสผ่านในรูปแบบ Plain Text โดยต้องเข้ารหัสด้วยอัลกอริทึม Password Hashing ที่ปลอดภัย และห้ามเปิดเผย Password Hash, Secret Key หรือ Environment Variables ใน API Response หรือ GitHub Repository
SR-SYS-05	**Input Sanitization & Injection**	ข้อมูลทั้งหมดที่รับจากผู้ใช้ต้องผ่านการตรวจสอบความถูกต้อง (Input Validation) และป้องกันช่องโหว่ Cross-Site Scripting (XSS) รวมถึงใช้งานผ่าน Django ORM เพื่อป้องกัน SQL Injection

Req ID	หมวดหมู่ (Category)	ข้อกำหนดด้านความปลอดภัย (Security Requirement)
SR-SYS-06	**Rate Limiting / Throttling**	ระบบต้องมีกลไกจำกัดความถี่ในการส่ง Request (Throttling) โดยเฉพาะในจุดที่มีความเสี่ยงสูง เช่น หน้า Login, Register และการอัปโหลดไฟล์ เพื่อป้องกัน Brute-Force และ Denial of Service (DoS)
SR-SYS-07	**Security Audit Logging**	ระบบต้องบันทึกเหตุการณ์สำคัญด้านความปลอดภัย (Security Logs) เช่น การเข้าสู่ระบบสำเร็จ/ล้มเหลว การเปลี่ยนรหัสผ่าน และการจัดการสิทธิ์ โดยจำกัดสิทธิ์ให้เฉพาะ Moderator (ตามขอบเขต) และ Administrator เท่านั้นที่เข้าดูได้

2. ข้อกำหนดความปลอดภัยแยกตามโมดูล (Module Security Requirements)

2.1 Authentication & User/Profile Module (S-02, S-03, S-04)

- **SR-AUTH-01 (Password Storage):** ระบบต้องจัดเก็บรหัสผ่านผู้ใช้งานด้วยการทำ Password Hashing ที่ปลอดภัย (เช่น PBKDF2 / Argon2 / bcrypt) และห้ามเก็บแบบ Plain Text โดยเด็ดขาด
- **SR-AUTH-02 (Registration Validation):** ระบบต้องตรวจสอบรูปแบบและความถูกต้องของข้อมูลก่อนการสมัครสมาชิกทุกครั้ง เพื่อป้องกันข้อมูลขยะหรือบัญชีซ้ำซ้อน
- **SR-AUTH-03 (Login Brute-Force Protection):** ระบบต้องจำกัดความถี่ในการพยายามเข้าสู่ระบบ (Rate Limiting / Throttling) เพื่อป้องกันการสุ่มเดารหัสผ่าน
- **SR-AUTH-04 (Session & Token Management):** ระบบต้องจัดการ Session หรือ Token อย่างปลอดภัย และตรวจสอบสิทธิ์ว่า Session นั้นเป็นของผู้ใช้เองจริงก่อนดำเนินการ Logout
- **SR-AUTH-05 (Profile Access & Privacy):** ผู้ใช้งานทั่วไป (Guest/Member) สามารถดูได้เฉพาะข้อมูลโปรไฟล์ที่กำหนดให้เป็นสาธารณะ และห้ามแก้ไขข้อมูลโปรไฟล์ของผู้อื่นยกเว้น Administrator

2.2 Community Module (S-05)

- **SR-COM-01 (Community Ownership):** ระบบต้องตรวจสอบสิทธิ์ความเป็นเจ้าของ (Community Owner) หรือสิทธิ์ Administrator ก่อนอนุญาตให้แก้ไขหรือลบข้อมูล Community
- **SR-COM-02 (Visibility Enforcement):** ระบบต้องตรวจสอบสถานะ Public / Private ของ Community ก่อนอนุญาตให้เข้าถึงรายละเอียดหรือรายชื่อสมาชิก
- **SR-COM-03 (Membership Integrity):** ระบบต้องป้องกันการเพิ่มหรือลบสมาชิกใน Community โดยผู้ที่ไม่มีสิทธิ์ตามนโยบายของ Community นั้นๆ
- **SR-COM-04 (Input Validation):** ข้อมูลชื่อ คำอธิบาย และการตั้งค่าของ Community ต้องผ่านการตรวจสอบก่อนบันทึกทุกครั้ง

2.3 Post, Feed & Comment Module (S-06, S-07, S-10)

- **SR-CNT-01 (Content Ownership & Moderation):** ระบบต้องตรวจสอบ Ownership ก่อนอนุญาตให้แก้ไขหรือลบ Post/Comment โดยอนุญาตให้ Moderator ลบเนื้อหาของผู้อื่นได้เฉพาะในขอบเขตที่ได้รับมอบหมาย (Scoped Access)
- **SR-CNT-02 (XSS Prevention):** ข้อมูลข้อความใน Post และ Comment ทั้งหมดต้องผ่านการกรองและ Escape อักขระอันตราย เพื่อป้องกันการฝังสคริปต์ (Cross-Site Scripting)
- **SR-CNT-03 (Private Content Isolation):** ในส่วนของ Feed และรายการโพสต์ ระบบต้องกรองข้อมูลตามสิทธิ์ของผู้ร้องขอ ห้ามแสดง Post หรือ Comment ที่อยู่ใน Private Community ให้กับผู้ที่ไม่มีสิทธิ์เข้าถึง
- **SR-CNT-04 (Pagination & Payload Limit):** Feed Module ต้องจำกัดจำนวนข้อมูลที่ดึงและแสดงผลต่อ 1 Request เพื่อป้องกันการดึงข้อมูลจำนวนมากเกินไปจนกระทบต่อ Availability ของระบบ

2.4 Follow & Like Module (S-08, S-09)

- **SR-INT-01 (Authenticated Action Only):** เฉพาะผู้ใช้งานที่เข้าสู่ระบบแล้ว (Member ขึ้นไป) จึงจะสามารถกด Follow หรือ Like ได้
- **SR-INT-02 (Self-Action & Target Validation):** ระบบต้องตรวจสอบว่า User ID หรือ Post ID ปลายทางมีอยู่จริง และไม่อนุญาตให้ผู้ใช้งานกด Follow บัญชีของตนเอง
- **SR-INT-03 (Duplicate Prevention):** ระบบต้องป้องกันการสร้างข้อมูล Follow หรือ Like ซ้ำซ้อน (เช่น การกด Like โพสต์เดิมซ้ำหลายครั้ง) โดยใช้การตรวจสอบระดับ Logic ร่วมกับ Database Constraint
- **SR-INT-04 (Relationship Ownership):** การกด Unfollow หรือ Unlike ต้องตรวจสอบ Ownership ว่าผู้ร้องขอเป็นผู้สร้างความสัมพันธ์หรือรายการ Like นั้นจริง

2.5 Media Module (S-11)

- **SR-MED-01 (File Type & Size Validation):** ระบบต้องจำกัดขนาดไฟล์สูงสุดและอนุญาตเฉพาะชนิดไฟล์รูปภาพที่ปลอดภัยเท่านั้น
- **SR-MED-02 (MIME / Content Inspection):** ระบบต้องตรวจสอบความถูกต้องของไฟล์จากเนื้อหาจริง (Magic Bytes / File Content) ไม่พึ่งพาเพียงนามสกุลไฟล์ (Extension) เพื่อป้องกันการอัปโหลดไฟล์อันตรายปลอมเป็นรูปภาพ
- **SR-MED-03 (Safe File Naming):** ระบบต้องเปลี่ยนชื่อไฟล์ที่อัปโหลดใหม่ให้ปลอดภัย (เช่น ใช้ UUID) เพื่อป้องกันช่องโหว่ Path Traversal หรือการเขียนทับไฟล์เดิม
- **SR-MED-04 (Media Access & Ownership):** ห้ามเปลี่ยนหรือลบไฟล์รูปภาพของผู้อื่น (ยกเว้น Admin) และต้องตรวจสอบสิทธิ์ Public/Private ก่อนเปิดให้เข้าถึงไฟล์ส่วนตัว

3. ความสอดคล้องกับความต้องการปกป้องทรัพย์สิน (CIA Triad Mapping)

ตารางสรุปการบังคับใช้ Security Requirements เพื่อปกป้อง Asset หลักของระบบตามหลักการ Confidentiality, Integrity และ Availability:

หลักการ CIA	ทรัพย์สินที่เกี่ยวข้อง (Key Assets)	ข้อกำหนดที่บังคับใช้ (Mapped Security Controls)
Confidentiality (การรักษาความลับ)	Password, Environment Variables, User Account, Private Community, Media Files	SR-AUTH-01 (Password Hashing), SR-SYS-04 (ซ่อน Secret/Env), SR-COM-02 และ SR-MED-04 (กรองสิทธิ์ Public/Private)
Integrity (ความถูกต้องของข้อมูล)	Database, Posts, Comments, Profile, Follow & Like Data	SR-SYS-03 (ตรวจสอบ Ownership ก่อนแก้ไข/ลบ), SR-SYS-05 (Input Validation / XSS Protection), SR-INT-03 (Database Constraint ป้องกันข้อมูลซ้ำ)
Availability (ความพร้อมใช้งาน)	Application Server, Database Server, Feed Module, Backup Storage	SR-SYS-06 (Throttling / Rate Limiting), SR-CNT-04 (จำกัดจำนวนข้อมูลต่อ Request ใน Feed), การสำรองข้อมูลบน Backup Storage (I-08)

4. การเชื่อมโยงกับเอกสารส่วนอื่นของทีม (Cross-Document Integration)

แนวทางการนำรหัสอ้างอิงไปใช้งานร่วมกับเอกสาร Threat Analysis และ Risk Register ของทีม

- **Threat Modeling (DFD):** สามารถนำรหัสอ้างอิง (SR-SYS-xx, SR-AUTH-xx) ไประบุเป็น Security Controls / Mitigation บนเส้น Trust Boundary ใน Data Flow Diagram ได้ทันที
- **Misuse Case:** สามารถนำข้อกำหนดแต่ละข้อไปเขียนกลับด้านเป็นสถานการณ์โจมตี เช่น จาก SR-MED-02 เขียนเป็น 'Attacker อัปโหลดไฟล์ Malware โดยปลอมนามสกุลเป็น .jpg'
- **Risk Register (ส่วนของมนต์):** สามารถอ้างอิงรหัส SR-xxx ในช่อง Existing Controls หรือ Mitigation Plan ของตารางประเมินความเสี่ยง เพื่อให้เอกสารทั้ง 4 ส่วนเชื่อมโยงกันอย่างสมบูรณ์